

TECHNICAL SPECIFICATION

AW Client Report Portal

Automated SACS (Cash-Flow) & TCC (Net-Worth) Reporting Platform

Field	Value
Document type	Technical Specification — for executive evaluation & authorisation
Product / project	AW Client Report Portal (working name; traceable to PRD v1.0)
Specification version	v1.0 (Draft for approval)
Date	18 June 2026
Prepared by	Engineering (AI Practice)
Prepared for	Product Owner / Product Manager and Executive Sponsors
Status	AWAITING AUTHORISATION
Classification	CONFIDENTIAL — contains client & financial process detail
Source basis	PRD v1.0 (2026-04-09) + discovery-call recording (2026-04-01) and a prior call

PURPOSE. This document translates the approved PRD into an engineering design and a phased delivery plan. It specifies the full target system — the immediately-authorized V1 build and the later phases that will be productised and released more broadly — so decision-makers can authorise V1 with full sight of where it leads. Sign-off page: Section 20.

Document Control

Revision History

Version	Date	Author	Summary of change
0.1	16 Jun 2026	Engineering	Initial structure from PRD
0.9	17 Jun 2026	Engineering	Full architecture, phasing, security sections
1.0	18 Jun 2026	Engineering	Draft issued for executive evaluation & PM/Owner authorisation

Distribution List

Name / Role	Function	Reason
Product Owner / PM	Approval authority	Authorise scope & phasing
Executive Sponsor(s)	Funding / strategy	Evaluate value & commercial model
Engineering Lead	Delivery	Confirm feasibility & estimates
Compliance / Security	Risk	Confirm data-handling posture
Client stakeholders	Andrew, Rebecca, Maryann	Validate business rules

Approvals Required

This specification is not in force until the Authorisation block in **Section 20** is signed by the Product Owner / Owner. Executive sponsors evaluate; the Product Owner authorises.

Table of Contents

Document Control	2
Revision History.....	2
Distribution List	2
Approvals Required	2
Table of Contents	3
1. Executive Summary	6
1.1 The recommendation	6
1.2 The forward vision (designed now, released later)	6
1.3 What executives are being asked to decide	6
1.4 Headline figures.....	6
2. Background & Context	7
2.1 The client and the problem	7
2.2 How this specification was derived	7
3. Goals, Non-Goals & Success Metrics	8
3.1 Business goals	8
3.2 Technical goals.....	8
3.3 Non-goals (for V1)	8
3.4 Success metrics (KPIs).....	8
4. Product Vision & Phasing Strategy	9
5. Scope	10
5.1 In scope — Phase 1 (authorised by this document)	10
5.2 Designed here, authorised later — Phases 2–4	10
5.3 Explicitly out of scope (all phases, unless re-scoped).....	10
6. System Architecture	11
6.1 Architectural principles.....	11
6.2 Logical components.....	11
6.3 Technology stack.....	11
6.4 Request flow (quarterly report)	12
6.5 How V1 enables later phases	12
7. Data Architecture & Model	14
7.1 Core entities	14
7.2 Relationships (summary)	14
7.3 Data lifecycle & retention	14
8. Functional Design	16
8.1 Client & Account Management (Phase 1).....	16
8.2 Quarterly Report Workflow (Phase 1).....	16
8.3 Calculation Engine (Phase 1)	16

8.4 PDF Generation (Phase 1)	16
8.5 Export (Phase 1)	16
8.6 Authentication & Access Control (Phase 1)	17
8.7 Integration Layer (Phase 2 — designed)	17
8.8 AI Agent Layer (Phase 3 — designed)	17
8.9 Client-Facing Expense Worksheet (Phase 3/4 — designed)	17
8.10 Report Distribution (Phase 3/4 — designed)	18
8.11 Multi-Tenancy, Admin & Billing (Phase 4 — designed)	18
9. Calculation Engine — Business Rules	19
9.1 SACS (cash-flow)	19
9.2 TCC (net worth)	19
9.3 Worked example (TCC, illustrative)	19
10. PDF Rendering Approach	20
11. Integration Architecture (Phases 2+)	21
12. AI & Agent Architecture (Phase 3)	22
12.1 Where AI is — and is not	22
12.2 Governance & guardrails	22
13. Security, Privacy & Compliance	23
13.1 Data sensitivity	23
13.2 Controls	23
13.3 Compliance posture	23
14. Non-Functional Requirements	24
15. Delivery Plan & Milestones	25
16. Effort, Cost & Commercial Model	26
17. Risks, Assumptions & Dependencies	27
17.1 Risk register	27
17.2 Assumptions to confirm	27
17.3 Dependencies	27
18. Acceptance Criteria & Definition of Done (V1)	28
19. Open Decisions Requiring Authorisation	29
20. Authorisation & Sign-Off	30
Authorisation decision	30
Appendix A — Glossary	31
Appendix B — Data-Point to Source Mapping	31
Appendix C — Traceability (requirement → source)	32
Appendix D — Source Artifacts	32

If the contents above appear empty, open in Word and choose *Update Field* (the document is configured to refresh on open).

1. Executive Summary

The firm produces two client-facing financial reports each quarter — a cash-flow summary (SACS) and a net-worth overview (TCC) — by manually gathering balances from several systems and assembling them in Canva and Word. The process takes roughly one full day per client meeting and is error-prone. This specification defines a secure web portal that reduces that preparation from a day to under an hour, eliminates manual arithmetic, and produces consistent, presentation-quality PDFs.

1.1 The recommendation

Authorise **Phase 1 (V1)** now: a single-firm portal for client setup, guided quarterly data entry, a deterministic calculation engine, and pixel-stable SACS & TCC PDF generation with export. V1 deliberately uses **no external integrations and no AI** — all data is entered by the team — which keeps it low-risk, fast, and fully within compliance constraints.

1.2 The forward vision (designed now, released later)

Per direction, this document also fully designs the later phases so the architecture chosen for V1 deliberately enables them with no rework: automated data integration (Phase 2), an AI agent layer for onboarding and data extraction (Phase 3), and a multi-tenant, productised release to other advisory firms (Phase 4). These are specified but not authorised by this document; each is its own funding decision. Designing them now means V1 is built multi-tenant-ready and integration-ready from day one.

1.3 What executives are being asked to decide

1. **Authorise the V1 build** and its acceptance criteria (Sections 8–9, 18).
2. **Note and steer the phased roadmap** (Section 4 & 15) — including the intent to productise later phases for public release.
3. **Resolve the open decisions** in Section 19 (e.g., Canva export priority, report storage, hosting region).
4. **Accept the security & compliance posture** in Section 13.

1.4 Headline figures

Metric	Today	With the portal
Prep time / client / quarter	~1 day	< 1 hour (target)
Manual math	All totals by hand	Fully automated
Report consistency	Canva drift / misalignment	Fixed, pixel-stable layout
Scale ceiling (no new hires)	~6 clients	12+ clients (V1); unbounded (Phase 4)
External data risk (V1)	n/a	None — manual entry only

2. Background & Context

2.1 The client and the problem

A lean, three-person financial-planning firm (principal Andrew; planner Rebecca, who holds Schwab access and compliance responsibility; and executive assistant Maryann) serves roughly six high- and ultra-high-net-worth households on retainer, with quarterly review meetings plus assets under management. Clients expect high professionalism and accuracy.

For every quarterly meeting the team hand-builds two reports, pulling data from **Pinnacle Bank, Charles Schwab, RightCapital and Zillow**, then assembling the figures in Canva and Word. The work is slow, repetitive, and a recurring source of arithmetic and alignment errors.

2.2 How this specification was derived

This document is the engineering response to an approved PRD (v1.0, 2026-04-09), which was itself synthesised from a recorded requirements call (2026-04-01) and a prior call. Requirements below are traceable to those sources; a traceability matrix is provided in Appendix C. Where the PRD recorded ambiguity, it is surfaced here as an open decision or an assumption to confirm rather than silently resolved.

ASSUMPTION TO CONFIRM. Certain identifiers in the PRD (the firm name, legal entity, and city) were attributed to third-party web research and were not stated on the call. They are treated here as unverified placeholders and must be confirmed before any client-facing or contractual use. See Section 17.2.

3. Goals, Non-Goals & Success Metrics

3.1 Business goals

- Cut quarterly report preparation from ~1 day to under 1 hour per client.
- Eliminate manual calculation errors through a single deterministic engine.
- Produce consistent, branded, presentation-quality PDFs with a fixed layout.
- Enable the firm to grow its client base without adding headcount.
- Consolidate scattered data (Excel, Dropbox, PreciseFP) into one source of truth.

3.2 Technical goals

- Deterministic, auditable calculations — no AI in the V1 numeric path.
- Pixel-stable PDF rendering independent of value length or account count.
- An architecture that admits later integrations and multi-tenancy without rework.
- Strong protection of PII and financial data, by design.

3.3 Non-goals (for V1)

- No automated pulling from RightCapital, Schwab, Pinnacle, or Zillow (Phase 2).
- No AI reasoning, classification, or generation in the report path (Phase 3).
- No client-facing access; the portal is internal-only in V1 (Phase 3/4).
- No redesign of Andrew's report templates — visual parity only, with light polish.

3.4 Success metrics (KPIs)

KPI	Baseline	Target (90 days post-launch)
Median prep time / report	~1 day	< 60 min
Calculation errors / quarter	Recurring	0
Reports generated via portal	0%	100% of quarterly reports
Re-work due to layout drift	Frequent	Eliminated
Clients served per staff member	~2	≥ 4

4. Product Vision & Phasing Strategy

The portal is designed as a platform delivered in four phases — built one block at a time, each shippable and valuable on its own, each enabled by the last. Phase 1 is authorised by this document; Phases 2–4 are designed here and authorised separately.

Phase	Theme	Capability	Release posture
1	Portal MVP	Client records, guided data entry, calc engine, SACS+TCC PDFs, export	Internal to this firm — AUTHORISE NOW
2	Automated data	Read-only, consented pulls (Plaid/Zillow/PreciseFP; Schwab & RightCapital where permitted)	Internal — later funding decision
3	AI agents	Onboarding agent, document/statement extraction, anomaly flagging — human-in-the-loop	Internal — later funding decision
4	SaaS platform	Multi-tenant, self-serve onboarding, billing, admin	PUBLIC RELEASE to advisory firms

WHY DESIGN IT ALL NOW. The expensive mistakes in V1 would be single-tenant data models, credential handling that can't be hardened, and a calc/render core entangled with the UI. By specifying Phases 2–4 up front, V1 is built with a tenant boundary, a credential vault seam, and a headless calculation+rendering core — so the future is a matter of funding, not re-architecture.

5. Scope

5.1 In scope — Phase 1 (authorised by this document)

- Client profile & account-structure management (lightweight CRM).
- One-click quarterly report workflow with a guided, validated data-entry form.
- Deterministic calculation engine implementing all SACS & TCC rules (Section 9).
- SACS and TCC PDF generation matching the existing templates (fixed layout).
- PDF download; Canva export subject to the decision in Section 19.
- Internal authentication, role-based access, and an audit log.
- Report history (re-download previous quarters), subject to storage decision (Section 19).

5.2 Designed here, authorised later — Phases 2–4

- Integration layer: PreciseFP, Plaid, Zillow, Schwab, RightCapital, Pinnacle, Dropbox, Canva, email.
- AI agent layer: client-onboarding agent; statement/document data-extraction agent; anomaly flagging.
- Client-facing surfaces: onboarding forms, expense-worksheet capture, monthly report distribution.
- Multi-tenancy, tenant administration, metered billing, and public self-serve onboarding.

5.3 Explicitly out of scope (all phases, unless re-scoped)

- Redesigning the report templates' visual identity.
- Acting as a system of record for trading, custody, or money movement.
- Tax advice, financial advice logic, or portfolio decisions — the portal reports; it does not advise.
- Podcast-production assistance — noted in the source as a separate *hiring* request, not a software build.

6. System Architecture

6.1 Architectural principles

5. **Deterministic core.** Calculations and rendering are a pure, headless library, independently testable and reusable by any future caller (API, agent, batch).
6. **Tenant-aware from day one.** Every record carries a tenant key even though V1 has one tenant — Phase 4 becomes configuration, not migration.
7. **Integration seam, unused in V1.** A provider interface and a credential vault boundary exist as the single place future data sources plug in.
8. **Secure by default.** Least privilege, encryption everywhere, full audit, no third-party data egress that compliance forbids.
9. **Simple where it can be.** Three users today; the UI is clean and server-rendered, with no heavy front-end framework.

6.2 Logical components

Component	Responsibility	Phase
Web UI	Client list, profile editor, report workflow, review & export screens	1
Application / API	Auth, request handling, orchestration, validation	1
Calculation engine	All SACS/TCC math; pure & deterministic	1
Rendering engine	SACS/TCC PDF templates; fixed layout, variable bubbles	1
Data store	Clients, accounts, liabilities, report runs, audit	1
Auth & RBAC	Identity, roles, sessions, MFA	1
Audit log	Immutable record of access & generation	1
Credential vault (seam)	Encrypted store for provider credentials/tokens	2
Integration providers	Pluggable read-only data fetchers	2
Agent runtime	Onboarding & extraction agents, human-in-the-loop	3
Tenant admin & billing	Provisioning, metering, self-serve onboarding	4

6.3 Technology stack

Layer	Choice	Rationale
Hosting	Railway (single region)	Team default; simple web app, low compute; region pinned for compliance

Layer	Choice	Rationale
Frontend	Server-rendered HTML/CSS/JS (light templating)	Three internal users; clean & fast; no SPA overhead
Backend	Python (FastAPI or Flask)	Strong PDF & data libraries; simple, well-understood
Calc engine	Pure Python module	Deterministic, unit-testable in isolation
PDF	WeasyPrint (HTML/CSS templates) — ReportLab fallback	HTML/CSS gives precise, maintainable fixed layouts; see Section 10
Database	SQLite (V1) on a Railway volume → PostgreSQL (Phase 2+)	6 clients = trivial volume; Postgres when concurrency/multi-tenant arrives
AuthN/Z	Session cookies + hashed passwords + TOTP MFA	Simple, standard, compliance-friendly
Secrets	Railway env vars (V1) → managed vault (Phase 2)	No secrets in code; vault seam ready
AI	None in V1 → governed model access (Phase 3)	V1 is deterministic; AI gated behind no-training terms

Environment variables (V1): RAILWAY_DATABASE_PATH, and CANVA_API_KEY only if Canva export is authorised.

6.4 Request flow (quarterly report)

10. User selects a client and clicks Generate Report.
11. App loads the client profile, pre-fills static fields, and presents a validated entry form for current balances.
12. On submit, the app validates completeness, then calls the calculation engine (pure function: inputs → totals).
13. Computed values feed the rendering engine, which returns SACS and TCC PDFs.
14. User reviews on-screen, then downloads PDFs and/or exports to Canva; the run is recorded in the audit log.

6.5 How V1 enables later phases

Future need	Enabled by this V1 decision	Phase
Automated data pulls	Manual entry sits behind the same provider interface a fetcher will implement	2

Future need	Enabled by this V1 decision	Phase
Credential security	Vault seam + read-only token model designed in from the start	2
AI extraction	Calc/render core is headless, so an agent can call it exactly as the UI does	3
Public multi-tenant SaaS	Tenant key on every row; Postgres migration path; RBAC already present	4

7. Data Architecture & Model

7.1 Core entities

Entity	Key attributes	Notes
Tenant	id, name, branding, region	One row in V1; spine of Phase 4
User	id, tenant_id, name, email, role, mfa_secret, password_hash	Roles: Owner, Planner, Assistant
Client (Household)	id, tenant_id, display_name, status, created_at	A household, not a person
Person	id, client_id, role (C1/C2), name, dob, ssn_last4	1–2 per household
Account	id, client_id, owner (C1/C2/Joint), category (retirement/non-retirement), type, acct_last4, has_cash_balance	Drives TCC bubbles
Trust	id, client_id, property_address, last_value, source	House value (Zillow in P2)
Liability	id, client_id, type, interest_rate, balance	0–3 typically
StaticFinancials	client_id, monthly_salary, monthly_expense_budget, reserve_target_inputs, floor	Changes rarely
ReportRun	id, client_id, period, entered_values(json), computed_values(json), created_by, created_at	One per quarterly generation
AuditEvent	id, tenant_id, user_id, action, entity, timestamp, ip	Immutable
ProviderCredential	id, tenant_id, provider, encrypted_token, scope, status	Phase 2 — vault-encrypted

7.2 Relationships (summary)

- A Tenant has many Users and Clients.
- A Client (household) has 1–2 Persons, many Accounts, 0–1 Trust, 0–N Liabilities, one StaticFinancials, and many ReportRuns.
- A ReportRun snapshots both the entered balances and the computed outputs, so any past report is exactly reproducible.

7.3 Data lifecycle & retention

- Static profile data is entered once and edited on change (new job, raise, new account).
- Dynamic balances are captured per ReportRun; the previous run seeds each field as a reference (“use last value”).
- ReportRuns are retained per the storage decision in Section 19 (default: retain, to power history & audit).
- Retention, export, and deletion honour the firm's compliance policy; PII fields are minimised (only SSN last-4 is stored).

8. Functional Design

Each module below lists its purpose, key behaviour, and acceptance signals. Modules 8.1–8.6 are Phase 1; 8.7–8.11 are designed for later phases.

8.1 Client & Account Management (Phase 1)

- Create/edit a household: names, DOB, auto-calculated age, SSN last-4, single or married (C1/C2).
- Define account structure: retirement accounts (IRA, Roth IRA, 401k, pension — never joint), non-retirement accounts (brokerage, joint, options), trust (property address), liabilities (type, rate).
- Enter static financials once: monthly after-tax salary, agreed expense budget, private-reserve target inputs.
- Client list view with last-report date; edit on change.

RULE. Retirement accounts cannot be joint; non-retirement accounts may be joint. The UI enforces this when accounts are added.

8.2 Quarterly Report Workflow (Phase 1)

- One-click Generate Report from a client profile.
- A single form, grouped by report section (SACS fields, then TCC fields), pre-filled with static data.
- Each dynamic field shows its last known value and a “use last value” option; manual override always available.
- Incomplete required fields are highlighted; a report cannot be generated until all required fields are filled.
- Clear field labels (e.g., “Roth IRA Balance”, “Schwab Brokerage Balance”, “Private Reserve Balance”, “Zillow Home Value”).

8.3 Calculation Engine (Phase 1)

A pure module that takes entered + static values and returns every total in real time. Full rules in **Section 9**. It performs no I/O and is covered by exhaustive unit tests.

8.4 PDF Generation (Phase 1)

- SACS: green Inflow circle, red Outflow circle, blue Private Reserve, connecting arrows; header with client name & date; page 2 with reserve, Schwab investment balance, target.
- TCC: green client-info bubbles (name, age, DOB, SSN last-4); retirement (top), non-retirement (bottom), trust (centre), liabilities (separate); gray total boxes; variable bubble count per client.
- Layout is fixed — nothing shifts or misaligns regardless of number size or account count; brand colours applied. See Section 10.

8.5 Export (Phase 1)

- Download SACS and TCC as separate, print-ready PDFs.
- Optional “Export to Canva” into the team workspace for last-minute visual edits (subject to Section 19).

- Report history: re-download prior quarters (subject to storage decision).

8.6 Authentication & Access Control (Phase 1)

- Email + password (hashed) with TOTP MFA; session cookies; idle timeout.
- Roles: Owner (full), Planner (full client + report), Assistant (data entry + generate).
- Every login, view of client PII, and report generation is written to the audit log.

8.7 Integration Layer (Phase 2 — designed)

A uniform read-only provider interface (fetch balances/values, return normalised fields, report freshness). Each source is an adapter behind that interface; the UI's manual entry is simply the “manual provider.” Adapters are added without touching the calc or render core.

Source	Method	Design notes
PreciseFP	API (one-time import)	Profile/onboarding data; map to Person/StaticFinancials
Plaid	Aggregation API	Preferred path for bank/investment balances; consented, read-only
Zillow	Zestimate lookup	Trust property value; clearly flagged as estimate
Schwab	Authorised-user access	Compliance-gated: per-user, read-only, never a shared agent login
RightCapital	API (guarded)	Known-unreliable; force-refresh then verify; treated as low-trust
Pinnacle Bank	Secure email today	Manual until a secure channel exists; do not automate insecurely

COMPLIANCE GUARDRAIL. No source is automated unless access is consented, read-only, attributable to a permitted user, and free of forbidden data egress. Where those cannot be met (e.g., a shared/third-party login), the field stays manual. This is a design rule, not a limitation to engineer around.

8.8 AI Agent Layer (Phase 3 — designed)

- **Onboarding agent:** emails the client the onboarding/expense forms, chases reminders, escalates to staff after a threshold, and lands structured data into the profile.
- **Extraction agent:** reads uploaded statements/PDFs and proposes balances for human confirmation — never auto-commits to a report.
- **Anomaly flagging:** highlights values that moved implausibly versus last quarter for staff review.

All agents are **human-in-the-loop** and sit outside the deterministic numeric path: they propose, a person disposes. Governance in Section 12.

8.9 Client-Facing Expense Worksheet (Phase 3/4 — designed)

- Replaces the emailed Excel sheet with a secure link clients complete; results flow into StaticFinancials with staff approval.

8.10 Report Distribution (Phase 3/4 — designed)

- Optional scheduled email delivery of finished reports (e.g., monthly) — off by default; the firm currently reports quarterly.
- Optional auto-save of generated reports to the firm's Dropbox (subject to Section 19).

8.11 Multi-Tenancy, Admin & Billing (Phase 4 — designed)

- Tenant provisioning, per-tenant branding, self-serve onboarding for new advisory firms.
- Usage metering and billing (cost-plus on data/compute); admin console for support.
- This is the **public-release** form of the product: the same headless core, exposed to many firms.

9. Calculation Engine — Business Rules

These rules are the deterministic heart of the system and must be implemented exactly. They are covered by unit tests with worked examples drawn from the source material.

9.1 SACS (cash-flow)

Output	Rule
Excess to Private Reserve	Excess = Inflow – Outflow
Private Reserve Target	Target = (6 × monthly expenses) + Σ insurance deductibles
Outflow	Agreed monthly budget (rounded up to create a buffer); auto-transferred inflow→outflow
Floor	\$1,000 minimum retained per bank account (constant)

9.2 TCC (net worth)

Output	Rule
Client 1 Retirement Total	Σ of Client 1 retirement account balances
Client 2 Retirement Total	Σ of Client 2 retirement account balances
Non-Retirement Total	Σ of all non-retirement balances (excludes the trust)
Grand Total Net Worth	C1 Retirement + C2 Retirement + Non-Retirement + Trust
Liabilities Total	Σ of liabilities, shown separately — NOT subtracted from net worth
Account balance vs cash	Investment account balance already includes its cash sub-balance (cash is shown, not added again)

CRITICAL. Two rules were emphasised repeatedly by the client and must be exact: the trust is NOT included in the non-retirement total (only in the grand total), and liabilities are NEVER subtracted from net worth. Unit tests assert both.

9.3 Worked example (TCC, illustrative)

Retirement: IRA \$11,000 + Roth IRA \$15,000 = \$26,000. Non-retirement: brokerage \$50,000. Trust: house \$450,000. Grand total = \$526,000. Liability: mortgage \$200,000 shown separately (net worth remains \$526,000).

10. PDF Rendering Approach

The reports must match Andrew's existing templates exactly, never shift, and handle a variable number of account bubbles. The recommended approach is HTML/CSS templates rendered to PDF by WeasyPrint.

Decision	Rationale
HTML/CSS templates → WeasyPrint	Precise, maintainable fixed layouts; easy brand styling; deterministic output
Absolute-positioned SACS diagram	Bubbles & arrows pinned to coordinates so nothing reflows with value length
Grid-driven TCC bubbles	A fixed grid with N slots per quadrant; empty slots collapse cleanly; 1–6 accounts/spouse supported
Server-side fonts & colours	Brand blue baked in; identical rendering across machines
ReportLab as fallback	If any layout proves hard in HTML, drop to programmatic drawing for that element

- Numbers are placed into fixed visual positions; long values shrink-to-fit within their box rather than pushing layout.
- Header carries client name and report date on both reports.
- Acceptance is visual parity against **sample PDFs requested from the team** — these are the source of truth for exact placement.

11. Integration Architecture (Phases 2+)

Integrations are deliberately absent from V1 and introduced behind the provider interface and credential vault described in Section 6. The sequence is risk-ordered: easiest and safest first.

Order	Integration	Why this order	Phase
1	PreciseFP one-time import	Read-only profile data; low risk	2
2	Zillow Zestimate	Single value; clearly an estimate	2
3	Plaid aggregation	Consented, read-only, replaces fragile RightCapital path	2
4	Schwab authorised-user read	High value but compliance-gated; per-user only	2/3
5	RightCapital (guarded)	Low-trust; only if Plaid migration is incomplete	2/3
6	Dropbox / Canva / email	Output-side conveniences	3

Credential handling: read-only scopes, per-user attribution, encrypted at rest in the vault, rotatable, revocable, and **never shared with an AI agent as a standing login**. A failed or stale pull degrades gracefully to manual entry with a clear flag.

12. AI & Agent Architecture (Phase 3)

12.1 Where AI is — and is not

- AI is **never** in the numeric path. Totals are always deterministic and auditable.
- AI assists at the edges: chasing onboarding inputs, extracting candidate values from documents, and flagging anomalies for human review.

12.2 Governance & guardrails

- **No-training guarantee:** client data is processed under terms that prohibit using it to train third-party models.
- **Human-in-the-loop:** agents propose; staff confirm before anything reaches a report.
- **Least data:** agents receive only the fields needed for their task.
- **Full audit:** every agent action and human decision is logged.
- **Compliance-aligned hosting:** no model provider or tool forbidden by the firm's policy (e.g., consumer Google tooling) is used.

13. Security, Privacy & Compliance

13.1 Data sensitivity

The system holds PII and financial data: names, DOB, **SSN last-4 only** (never full SSN), account types with last-4 numbers, balances, and net worth. It is a confidential system throughout.

13.2 Controls

Area	Control
In transit	TLS everywhere; HSTS
At rest	Encrypted database volume; sensitive columns additionally encrypted (Phase 2 vault for credentials)
Access	Role-based; least privilege; MFA on every account
Audit	Immutable log of logins, PII views, report generations, and (Phase 3) agent actions
Secrets	Never in code; env vars (V1) → managed vault (Phase 2); rotatable
Data egress	No data sent to services the firm's compliance policy forbids
Backups	Encrypted, region-pinned, tested restore
Tenancy	Tenant key enforced in every query; isolation tested before Phase 4

13.3 Compliance posture

- Honour the firm's stated constraints: **no forbidden consumer tooling**; Schwab/RightCapital credentials are not shared with agents; bank data stays on secure channels.
- Hosting region pinned to satisfy data-residency expectations (confirm in Section 19).
- A path to **SOC 2 Type II** is assumed for the Phase 4 public release; controls above are chosen to be compatible.
- The portal reports facts; it does not provide financial or tax advice, keeping it outside advice-specific regulatory scope.

14. Non-Functional Requirements

Attribute	Requirement
Performance	Report generation (both PDFs) in < 10 s; form interactions feel instant
Availability	V1: business-hours reliability on a single region. Phase 4: 99.9% target
Scalability	V1: tens of clients, 3 users. Architecture scales to thousands of clients across tenants
Usability	A non-technical assistant completes a report unaided; clear validation and “use last value”
Accessibility	Legible type, sufficient contrast, keyboard-navigable forms
Maintainability	Headless calc/render core with high unit-test coverage; templates editable without code changes
Observability	Health checks, error logging, uptime monitoring (team-hosted)
Portability	SQLite→PostgreSQL migration path defined; no lock-in on the render core

15. Delivery Plan & Milestones

Indicative, assuming one engineer with part-time review; calendar starts on authorisation. Phases 2–4 are planning estimates for the forward view, not part of this authorisation.

Phase	Milestone	Deliverables	Indicative
1	M1 Foundations	Data model, auth/RBAC, client & account CRUD	Wk 1–2
1	M2 Engine	Calculation engine + full unit tests (Section 9)	Wk 2–3
1	M3 Reports	SACS & TCC PDF templates to visual parity	Wk 3–5
1	M4 Workflow	Guided entry, validation, history, export	Wk 5–6
1	M5 V1 Launch	Hardening, UAT with the team, go-live	Wk 6–7
2	Integrations	PreciseFP, Zillow, Plaid; vault; Schwab (gated)	+4–6 wk
3	Agents	Onboarding & extraction agents; distribution	+6–8 wk
4	SaaS	Multi-tenancy, billing, self-serve, SOC 2 path	Quarter-scale

Prototype of V1 can be demonstrated within roughly **one week** of authorisation, with full V1 around six to seven weeks.

16. Effort, Cost & Commercial Model

Costs are indicative and should be confirmed against the prevailing commercial agreement.

Item	Basis
V1 build	Flat per-build fee (“one credit,” ≈ \$500 under the current plan); ~6–7 weeks effort
Hosting & ops	Provider hosts, monitors uptime, and fixes defects (included in membership)
Usage (Phase 2+)	Metered data/compute at cost + ~20%; framed as tens of dollars/month at this scale
Membership	Monthly plan under which credits are issued and apps are hosted
Phases 2–4	Each is a separate build/credit decision; estimated in Section 15

VALUE FRAME. At ~6 clients × 4 quarters, V1 saves on the order of 20+ staff-days/year and removes a recurring error class. The larger prize is capacity: serving 12+ clients (and, via Phase 4, an external market) without proportional hiring.

17. Risks, Assumptions & Dependencies

17.1 Risk register

Risk	Likelihood	Impact	Mitigation
Exact visual parity with templates is fiddly	Med	Med	Request sample PDFs up front; HTML/CSS + ReportLab fallback; UAT sign-off on layout
Unverified firm/identity details	Med	Low	Treat as placeholders; confirm before client-facing use (17.2)
Scope creep from “dreaming big” items	Med	Med	Phase boundaries; one block at a time; Section 19 decisions
Compliance limits on data sources	High	Low	By design, those stay manual until safe; no forced automation
RightCapital data unreliable	High	Low	Low-trust adapter; prefer Plaid; manual override always
PII exposure	Low	High	Encryption, RBAC, MFA, audit, SSN last-4 only, region pinning
Single-engineer key-person risk	Med	Med	High test coverage; documented headless core; simple stack

17.2 Assumptions to confirm

- Firm name, legal entity, and city (attributed to web research, not stated on the call) are unverified placeholders.
- Sample SACS/TCC PDFs and the “Data Point List” document will be provided as the layout source of truth.
- Current cadence is quarterly; monthly distribution is a future option, off by default.

17.3 Dependencies

- Timely access to the team for UAT and business-rule confirmation.
- Provider accounts/credentials for Phase 2 (Plaid, PreciseFP, etc.) when those phases are authorised.

18. Acceptance Criteria & Definition of Done (V1)

15. A client (single or married) can be created with full profile, accounts, liabilities, trust, and static financials.
16. Generate Report pre-fills static data and presents a validated entry form with “use last value” and override.
17. A report cannot be generated with missing required fields.
18. All SACS & TCC totals match Section 9 exactly, verified by unit tests including the emphasised rules (trust handling; liabilities not subtracted).
19. SACS and TCC PDFs match the sample templates to the team's visual satisfaction; layout is stable across value sizes and account counts (1–6 per spouse).
20. PDFs download cleanly; Canva export works if authorised; prior reports can be re-downloaded if storage is enabled.
21. Auth, RBAC, MFA, and audit logging are in place; security checklist (Section 13) passes.
22. The team completes a real quarterly report end-to-end in under an hour during UAT.

19. Open Decisions Requiring Authorisation

These are product/owner calls. Defaults are proposed so silence does not block the build.

Decision	Options / proposed default	Owner
Canva export	Build now vs defer. Default: defer; portal PDF first (client said they'd rather not use Canva/Word at all)	PM/Owner
Report storage	Store report history vs generate-and-forget. Default: store (enables history & audit)	PM/Owner
Dropbox auto-save	In V1 vs later. Default: later (lightweight to add once confirmed)	PM/Owner
Monthly email distribution	Build vs defer. Default: defer (firm reports quarterly)	PM/Owner
Hosting region	Confirm region for data residency/compliance	Owner + Compliance
Identity placeholders	Confirm firm name/entity/city before client-facing use	Owner
Phase 2 trigger	When to authorise automated integrations	Exec Sponsor

20. Authorisation & Sign-Off

By signing below, the Product Owner / Owner authorises the **Phase 1 (V1)** build as scoped in Sections 5, 8, 9 and 18, acknowledges the forward roadmap (Sections 4 & 15) including the intent to productise later phases for public release, and records decisions on the items in Section 19. Executive sponsors sign to confirm evaluation and funding support.

Role	Name	Signature	Date
Product Owner / Owner			
Product Manager			
Executive Sponsor			
Engineering Lead			
Compliance / Security			

Authorisation decision

Decision	Mark one
APPROVED — proceed with V1	☐
APPROVED WITH CHANGES (note below)	☐
NOT APPROVED	☐

Notes / conditions:

Appendix A — Glossary

Term	Meaning
SACS	Simple Automated Cash Flow — one-page diagram of monthly money flow (Inflow → Outflow → Private Reserve)
TCC	Total Client Chart — one-page net-worth overview by account type
Inflow	Take-home pay deposited to the primary checking account
Outflow	Agreed monthly expense budget (rounded up) transferred from inflow
Private Reserve	High-yield savings holding the excess; target = 6 × expenses + insurance deductibles
Trust	Usually the client's home; value from Zillow Zestimate
Floor	\$1,000 minimum kept in each bank account
Pinnacle Bank	Preferred bank; balances via secure email 2 days before meetings
RightCapital	Planning aggregator; has an API but data is often stale/disconnected
PreciseFP	Onboarding questionnaire tool; closest existing thing to a CRM
Plaid	Bank/investment data aggregation API (preferred automation path)

Appendix B — Data-Point to Source Mapping

Field	Report	Source (V1 = manual entry)
Client salary (inflow)	SACS	Onboarding / expense worksheet
Monthly expense budget (outflow)	SACS	Monthly expense worksheet (Excel)
Private reserve balance	SACS	Bank balance (secure email, 2 days prior)
Schwab investment balance	SACS/TCC	Schwab (authorised users only)
Reserve target inputs	SACS	Agreed: 6× expenses + insurance deductibles
Names, DOB, SSN last-4	TCC	PreciseFP / onboarding
Retirement balances	TCC	RightCapital / statements / Schwab
Non-retirement balances	TCC	RightCapital / statements
Home value (trust)	TCC	Zillow Zestimate
Liabilities (type, rate, balance)	TCC	RightCapital / client statements

Appendix C — Traceability (requirement → source)

Requirement	PRD / call ref	Spec section
One-time client setup / CRM-lite	US1; call 35:44	8.1, 7
Guided entry + auto-calculation	US2; call 25:36, 33:34	8.2, 8.3, 9
Exact calc rules (trust, liabilities)	US2 notes; call 24:28, 26:15	9.2
Fixed-layout SACS & TCC PDFs	US3; call 11:15, 13:57	8.4, 10
Export (PDF / Canva)	US4; call 52:56	8.5, 19
No APIs / no AI in V1	PRD stack note	3.3, 6.3, 11, 12
Automated pulls deferred	Out-of-scope; call 48:14, 49:06	8.7, 11
Onboarding agent / distribution	Future; call 16:15, 43:36	8.8, 8.10

Appendix D — Source Artifacts

- PRD: “PRD AI Engineer Test.pdf” (v1.0, 2026-04-09) — 14 pages.
- Discovery call recording: “AW - AI Test Project.mp4” (2026-04-01, ~55 min) + a prior call referenced therein.
- Derived analysis reports: “AW_AI_Test_Project_Report.md” and “PRD_AI_Engineer_Test_Report.md”.

END OF SPECIFICATION • CONFIDENTIAL